



中华人民共和国通信行业标准

YD/T XXXX—XXXX

基于公众电信网的车载远程通信终端网络安全技术要求

Network security technical requirements for vehicular telecommunication terminal based on public telecommunication networks

（报批稿）

XXXX-XX-XX 发布

XXXX-XX-XX 实施

目 次

前 言..... II

引 言..... III

1 范围..... 1

2 规范性引用文件..... 1

3 术语定义..... 1

4 缩略语..... 1

5 系统架构..... 2

6 安全技术要求..... 2

 6.1 硬件安全..... 2

 6.2 接口安全..... 2

 6.3 操作系统安全..... 3

 6.4 应用安全..... 3

 6.5 漏洞管理..... 4

 6.6 通信安全..... 4

 6.7 OTA 安全..... 5

 6.8 数据安全..... 5

参考文献..... 7

前 言

本文件按照 GB/T 1.1-2020《标准化工作导则 第1部分：标准化文件的结构和起草规则》的规则起草。

请注意本文件的某些内容可能涉及专利。本文件的发布机构不承担识别这些专利的责任。

本文件由中国通信标准化协会提出并归口。

本文件起草单位：中国信息通信研究院、博鼎实华（北京）技术有限公司、中国联合网络通信有限公司、浙江蚂蚁小微金融服务集团股份有限公司、北京奇虎科技有限公司、郑州信大捷安信息技术股份有限公司、无锡物联网创新中心有限公司。

本文件主要起草人：徐晓娜、李煜光、袁琦、田琛、董霁、傅瑜、王翠翠、姚一楠、刘献伦、林冠辰、董接莲、李鑫、张永安。

引 言

车载远程通信终端主要用于车辆与其他车辆、行人、道路交通设施或远程服务器进行通信，是智能网联汽车的关键通信部件。车载远程通信终端一方面可与CAN总线通信，实现指令和信息的传递，另一方面内置调制解调器，可通过数据网络、语音、短信等与车联网云平台交互，是车内外信息交互的纽带。

车载远程通信终端作为联网汽车的关键信息交互部件，其信息安全能力影响着整个车辆的安全性。目前车载远程通信终端可能受到的信息安全威胁包括协议破解、信息泄露、中间人攻击等，任何攻击方式都有可能威胁车辆乃至人身安全。因此针对车载远程通信终端制定信息安全技术要求，有助于提高车载远程通信终端企业与车辆制造企业的信息安全意识，提高车联网行业的安全能力。

国际上在车载信息交互系统信息安全标准方面已经着手研制，部分已经发布。技术发展趋势上，目前安全传输和数据安全防护技术都是应用在ICT领域。由于车载信息交互系统自身业务和物理资源的限制，这些传统的安全技术不完全适用于车联网领域。车联网的信息安全属于传统信息安全和汽车电子的交叉领域，目前没有成熟的安全解决方案，相应的行业标准也亟待建立。

基于公众电信网的车载远程通信终端网络安全技术要求

1 范围

本文件规定了车载远程通信终端的硬件安全要求、接口安全要求、操作系统安全要求、应用安全要求、漏洞管理安全要求、通信安全要求、OTA安全要求、数据安全要求等。

本文件适用于各类需要接入公众电信网进行远程通信的车辆类型的车载远程通信终端的研发、设计和测试。

2 规范性引用文件

本文件没有规范性引用文件。

3 术语定义

3.1

车载远程通信终端 `vehicular telecommunication terminal`

位于车辆内部，用于该车辆通过远程通信协议和其他车辆、行人、道路交通设施或远程服务器进行数据传输、存储、处理与使用的终端设备。

3.2

公众电信网 `public telecommunication network`

面向公众的电信网络，通常指运营商网络，如电信、联通、移动、广电网络等。

4 缩略语

下列缩略语适用于本文件。

App	应用程序	Application
BLE	蓝牙低功耗	Bluetooth Low Energy
CAN	控制器局域网络	Controller Area Network
CVE	通用漏洞披露	Common Vulnerabilities and Exposures
CNNVE	中国通用漏洞披露	China National Vulnerability Database of Information Security
ECU	电子控制单元	Electronic Control Unit
HTTPS	超文本传输安全协议	Hypertext Transfer Protocol Secure
HUK	硬件唯一密钥	Hardware Unique Key
IVI	车载信息娱乐系统	In-Vehicle Infotainment
OBD	车载诊断系统	On-Board Diagnostic
OTA	空中下载技术	Over-the-Air Technology
RoTPK	可信根公钥	Root of Trust Public Key

TLS	安全传输层协议	Transport Layer Security
TSP	汽车远程服务提供商	Telematics Service Provider
UID	唯一识别码	Unique Identification
WPA	Wi-Fi网络安全接入	Wi-Fi Protected Access

5 系统架构

基于公众电信网的车载远程通信终端网络架构主要包括车内网络、公众电信网和TSP三部分，其网络架构图如图1所示。

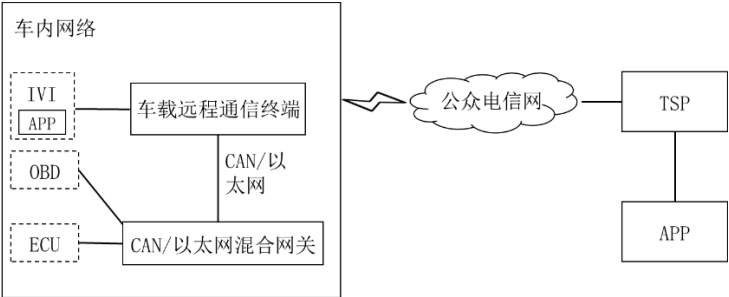


图1 基于公众电信网的车载远程通信终端网络架构

车内网络中，车载远程通信终端与车辆主体通过车辆总线或以太网通信，IVI、OBD、ECU等系统均通过车载远程通信终端与TSP进行通信，其中OBD、ECU通过CAN/以太网网关与车载远程通信终端连接，实现对车辆状态信息、控制指令、远程诊断和按键状态信息等的传递。

用户可以通过App来远程控制汽车车身功能，通过IVI上的App来本地控制汽车车身功能。

本文件的主要规范对象为车载远程通信终端，其安全架构如图2所示。



图2 基于公众电信网的车载远程通信终端安全框架

基于公众电信网的车载远程通信终端安全架构主要包括8个部分：硬件安全、操作系统安全、接口安全、应用安全、通信安全、OTA安全、漏洞管理、数据安全。本文件主要围绕这8个部分提出相应安全技术要求。

6 安全技术要求

6.1 硬件安全

车载远程通信终端的硬件应满足以下安全要求：

- a) 板载芯片应提供可信根供终端使用，例如HUK、RoTPK、UID、BootROM等；
- b) 应具有存储和隔离敏感数据的安全区域或安全模块；
- c) 应防止非授权获取或篡改在安全区域或安全模块中一次性写入的敏感信息；
- d) 安全区域或安全模块应具有检测与处置非授权访问的机制。

6.2 接口安全

车载远程通信终端的接口应满足以下安全要求：

- a) 在板载芯片中，不应存在可非法对芯片内存进行访问或者更改芯片功能的隐蔽接口；
- b) 应对板载芯片调试接口进行禁用或实施安全访问控制；
- c) 外部接口应无法直接访问或导出重要数据。

6.3 操作系统安全

6.3.1 操作系统加固

车载远程通信终端的操作系统应满足以下安全要求：

- a) 应禁用或删除无用账号；
- b) 应具备口令安全机制，包括但不限于以下要求：
 - 口令复杂度应满足一定要求，例如最少应包括大写字母、小写字母、数字与特殊符号；
 - 如果操作系统支持口令重置，则应保证重置之后的口令不是统一的默认值；
 - 在口令多次输入错误之后应重新认证用户身份，或对操作系统锁定特定时长。
- c) 应具有访问控制机制，依据安全策略控制用户、进程等主体对文件、数据库等客体的访问；
- d) 应关闭不必要的服务。

6.3.2 操作系统安全启动

车载远程通信终端的操作系统应满足以下安全要求：

- a) 操作系统应具备安全启动机制，即操作系统的启动应初始化为可信根，所有操作系统程序（包括Bootloader、firmware image等）应直接或间接被可信根进行完整性与可靠性检查之后才能启动；
- b) 应能够验证应用的来源和完整性，保证操作系统只加载启动可信的应用程序。

6.3.3 操作系统更新

车载远程通信终端的操作系统应满足以下安全要求：

- a) 软件更新时，应保证更新软件包的来源可靠性，并对接收到的更新文件进行完整性校验；
- b) 不应允许操作系统版本降级更新；
- c) 应具有备份和恢复能力，能够在软件更新失败时进行必要的操作，比如回滚到更新之前的版本，避免更新失败导致系统失效；
- d) 软件更新应在约定的工况（例如：非行驶状态）和车辆系统状态（例如：电瓶电量满足要求）下，并在用户确认后执行。

6.3.4 操作系统日志审计

车载远程通信终端的操作系统应满足以下安全要求：

- a) 应具有日志功能，记录用户操作、系统日志等信息；
- b) 应支持日志上传至远程服务器的功能，并采取安全的方式传输；
- c) 应采取访问控制机制，对日志读取写入的权限进行管理；
- d) 应对日志存储进行安全防护。

6.4 应用安全

车载远程通信终端的应用应满足以下安全要求：

- a) 不应有非授权收集或泄露用户信息、非法数据外传等恶意行为；

- b) 禁止以明文形式存储用户敏感信息（例如：用户口令、证件号码、交易信息、私钥等）；
- c) 宜具有对抗逆向分析的安全机制；
- d) 应采用代码签名认证机制，且代码签名机制符合相关标准要求。

6.5 漏洞管理

车载远程通信终端的系统软件和应用软件，不应存在未公开的访问接口，也不应存在中国汽车行业漏洞共享平台（CAVD）、国家信息安全漏洞共享平台（CNVD）、中国国家信息安全漏洞库（CNNVD）、CVE、CNCVE等公开发布了6个月及以上未经处置的高危及以上安全漏洞。

6.6 通信安全

6.6.1 访问控制安全

车载远程通信终端的访问控制应满足以下安全要求：

- a) 应在创建远程通信连接时对远程设备与服务器进行身份认证；
- b) 应对网络通信的相关访问操作和安全事件生成日志记录；
- c) 应具备流量控制功能，用于过滤进入或传输总线网络的数据，防止未经授权的实体向车辆总线网络传输数据；
- d) 应具备入侵检测功能，通过对外部连接或总线中数据流量等信息的监控，及时发现通信网络中是否有违反安全策略的行为。

6.6.2 通信网络安全

车载远程通信终端应具备入侵检测功能，通过对外部连接或总线中数据流量等信息的监控，及时发现通信网络中是否有违反安全策略的行为。

6.6.3 通信协议安全

车载远程通信终端的通信协议应满足以下安全要求：

- a) 应使用安全的通信协议，例如HTTPS、(D)TLS v1.2及以上版本等；
- b) 应采用加密、完整性检查等安全措施保护关键通信数据的机密性、完整性；
- c) 应具有安全存储功能，将用于安全通信的密钥等相关信息进行加密存储；
- d) 应能够抵抗拒绝服务攻击和重放攻击。

6.6.4 通信接口安全

车载远程通信终端的通信接口应满足以下安全要求：

- a) 应支持路由隔离功能，将执行控制车辆指令、收集用户敏感信息等功能的业务平台的通信进行隔离，同时将对外通信中非核心业务平台的外网通信等进行隔离；
- b) 与能执行控制车辆指令、收集个人敏感信息等功能的业务平台间通信时，宜采用专用网络或虚拟专用网络通信，与公网隔离；
- c) 对于蓝牙通信接口，应满足以下要求：
 - 使用BLE4.2及以上版本协议的模块应使用LE Secure Connections功能；
 - 应采取措施防止中间人攻击；
- d) 对于蜂窝通信接口，应满足以下要求：
 - 对3G及以上网络，应具备双向鉴权能力，防止伪基站攻击，防止附着一个不可信的网络；
- e) 对于Wi-Fi通信接口，应满足以下要求：

-应采用WPA3及以上版本协议，保证接入安全和数据传输安全。

6.7 OTA 安全

若车载远程通信终端支持OTA功能，则应满足以下安全要求：

- a) 系统升级时，车载远程通信终端和远程服务器之间应采用双向认证；
- b) 升级包的传输应采用加密措施；
- c) 应对升级包进行验证，校验升级包的完整性和来源可靠性；
- d) 应具有升级管理功能，包括：版本管理、版本备份等；
- e) 应具备升级版本防回退校验功能；
- f) 当升级失败时，应恢复到更新前可用的版本。

6.8 数据安全

6.8.1 数据采集

车载远程通信终端的数据采集应满足以下安全要求：

- a) 对用户数据的采集应在提供相应服务的同时进行，数据采集类型和数量应遵循最小必要原则；
- b) 采集模块相关代码（包括固件、驱动程序等）应具备完整性保护措施和来源可靠性验证措施；
- c) 采集模块应实施访问权限控制，防止采集的源数据被窃取、被破坏。

6.8.2 数据存储

车载远程通信终端的数据存储应满足以下安全要求：

- a) 用户敏感数据（例如：用户身份、位置信息）应存储在物理或软件隔离的专用存储区域，同时为保存数据的文件设置适当的访问权限，或加密存储在外置存储器等通用存储区域；
- b) 应采用加密形式保存用户生物特征数据；
- c) 未向用户明示或未经用户同意禁止擅自存储或修改用户数据；
- d) 用户数据存储期限应为用户授权使用的目的所必需的最短时间，法律法规另有规定或者用户另行授权同意的除外。

6.8.3 数据使用

车载远程通信终端的数据使用应满足以下安全要求：

- a) 对用户数据的访问使用，应建立最小授权的访问控制策略；
- b) 需要展示的用户数据，应进行去标识化处理。

6.8.4 数据传输

车载远程通信终端的数据传输应满足以下安全要求：

- a) 应对用户敏感数据（例如：用户身份、位置信息）进行加密传输；
- b) 用户敏感数据（例如：用户身份、位置信息）向车外传输时，应进行脱敏处理。

6.8.5 数据删除

车载远程通信终端的数据删除应满足以下安全要求：

- a) 应提供手段协助清除数据因不同设备间共享、业务终止、自然灾害、合同终止等遗留的数据，对日志的留存期限应不少于六个月。

注：该要求来源于《工业和信息化部关于加强车联网网络安全和数据安全工作的通知》（工信部网安〔2021〕134号）。

- b) 共享类应用（例如：共享汽车），在用户退出后，该用户的敏感数据应被清空；
- c) 车载远程通信终端更换件后，应同步相关用户数据至新件，并删除换下的旧件中存放的数据；
- d) 应对不再使用的敏感数据进行不可恢复地删除。

参 考 文 献

- [1] 《工业和信息化部关于加强车联网网络安全和数据安全工作的通知》，2021，工业和信息化部；
 - [2] T-REC-X.1374-202010 Security requirements for external interfaces and devices with vehicle access capability;
 - [3] GB/T 35273-2020 信息安全技术 个人信息安全规范；
 - [4] YD/T 3751-2020 车联网信息服务 数据安全技术要求。
-